

基于模拟的安全性定义和证明

王涛 陕西师范大学 water@snnu.edu.cn

2026 年 6 月 12 日

摘要

背景：我一直以为对于基于模拟的安全性定义和证明自己懂了一点，现在看，理解的还是不透。为此，我觉得需要彻底解决这个问题，一方面让自己能够理解透彻；另一方面写个东西方便日后学生容易懂。内容：本文力图系统性地讲解密码学中基于模拟的安全（Simulation-Based Security）证明范式，从概念、定义和典型案例等方面展开。特别地，以几个典型密码原语（公钥加密、承诺协议、密钥交换、零知识证明、混合论证）为例展开完整分析，覆盖系统模型定义、基于模拟的形式化安全模型、方案构造、基于模拟的安全性证明四个环节。结论：越写问题越多，以为自己理解透了，其实还有很多需要思考和整理。所谓“系统性地讲解”，只能尽力了，毕竟初心是好的。

目录

1	引言	4
1.1	“Simulation-based” 概念起源与发展	5
1.2	内容安排	6
2	基础知识	7
2.1	密码学安全性证明的基本概念	7
2.2	基于游戏的安全性证明及实例	9
2.3	安全模型实例：IND-CPA	9
3	基于模拟的安全性定义	12
3.1	真实协议和其执行过程	13
3.2	理想世界和其执行过程	15
3.3	真实世界 vs 理想世界	16
3.4	基于模拟的安全性定义	17
4	公钥加密	20
4.1	修订后的加密方案语义安全定义	20
4.2	基于模拟的证明	21
5	承诺协议	22
5.1	系统模型	23
5.2	安全模型与安全性定义	24
5.3	隐藏性 (Hiding)	25
5.4	绑定性 (Binding)	26
5.5	安全属性的不可能性结果	27
5.6	方案构造 I: Pedersen 承诺协议 (计算绑定 + 统计隐藏)	28
5.7	方案构造 II: Naor 承诺协议 (统计绑定 + 计算隐藏)	31
5.8	结论	35
6	零知识证明: Goldreich-Micali-Rackoff (GMR) 图同构协议	36
6.1	系统模型	36
6.2	安全模型 (基于模拟的零知识定义)	36
6.3	方案构造	37
6.4	完整安全证明	38

7	密钥交换：Sigma 协议	40
7.1	系统模型	40
7.2	安全模型（基于模拟的会话密钥安全）	40
7.3	方案构造	41
7.4	完整安全证明	41
8	基于模拟的 Hybrids	43
8.1	Hybrids 的构造逻辑	43
8.2	Hybrids 的分析方法	43
8.3	Canetti-Krawczyk (CK) 密钥协商协议	43
9	总结	49
9.1	经典方案的模拟逻辑本质	49
9.2	模拟范式的核心优势	49

1 引言

根据可证明安全的思想，将一个密码算法或者协议部署在实际安全系统之前，我们首先需要证明它可以抵御所有的攻击手段。我们先针对实际应用环境中假想的敌手的能力来构建一个敌手模型 (adversarial model)。在这个敌手模型中，我们规范了敌手可以做什么、不能做什么。下一步，我们需要证明的是任何敌手在规定的能力约束范围内都无法攻破某个密码算法或者协议。一旦达到这个目的，我们的目标算法或者协议就被称为是可证明安全的 [1]。

可证明安全的核心思想是“归约” (reduction)：我们需要把错综复杂的密码算法或者协议的安全性问题归约到某个（或者某几个）极微本原 (atomic primitives, 安全方案或协议的最基本组成构件或模块，俗称原语)，那么密码学家只需要分析这几个极微本原的安全性就可以了。

基于游戏的安全性定义是可证明安全中最常用的定义方法之一。它通过构建一个形式化的安全游戏来描述敌手与挑战者之间的交互过程，定义了敌手在该游戏中获胜的条件，并将协议的安全性归约到敌手在该游戏中的成功概率上。这种方法直观且易于理解，适用于许多基本密码原语的安全分析。然而，基于游戏的定义也有自己的局限性。其中最重要的特点是，一般来说它只能模拟协议在孤立环境下单独运行的安全性，无法对复杂并发环境的安全性进行建模。

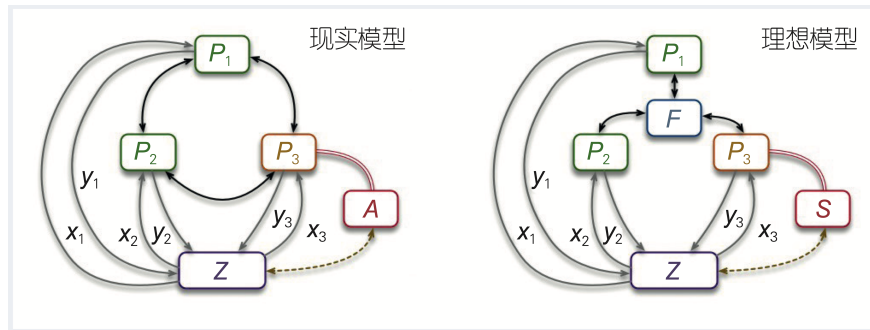


图 1: 基于模拟的安全性定义：真实世界与理想世界视图比较 [1]

基于模拟的安全性定义 (Simulation-based Security) 是现代密码学中用于形式化描述协议安全性的一种根本性范式。如图1所示，其核心思想是：协议参与者 (P_1, P_2, P_3)、攻击者 ($\mathcal{A}$)、仿真攻击者 ($\mathcal{S}$) 和环境机 ($\mathcal{Z}$) 都是由概率多项式时间 (Probabilistic Polynomial Time, PPT) 交互通用图灵机 (ITM) 来模拟。设计者把对于目标密码协议的功能性要求和安全性要求都通过定义 $\mathcal{F}$ 来模拟。该密码协议的安全性强弱完全取决于 $\mathcal{F}$ 的具体定义。环境机 ($\mathcal{Z}$) 的目的是区分现实世界和理想世界，在运行过程中它为协议参与者提供协议输入，并可以读取协议输出；同时，环境机可以实时和攻击者通信。如果对于任何攻击者通过

攻击现实世界中的协议所产生的影响都可以被仿真攻击者在理想世界中模拟，那么环境机将无法区分现实/理想世界。我们就认为该密码协议的安全性至少和在理想世界中用 $\mathcal{F}$ 计算一样安全 [1]。

1.1 “Simulation-based” 概念起源与发展

模拟思想与零知识证明的发展密切相关。早期关于零知识 (zero-knowledge) 的工作由 Goldwasser、Micali 与 Rackoff(会议版本为 1985 年) 等人奠定，证明了可以在不泄露证据的前提下进行证明 [2]。随后，Goldreich、Micali 和 Wigderson (GMW, 1987) 等人的工作把“理想/真实世界”式的模拟思想引入到安全多方计算 (MPC) 与协议安全的形式化定义中，明确了通过构造模拟器来证明协议不泄露额外信息的范式 [3]。Beaver、Micali、Rogaway 明确使用 Trusted Party (可信第三方) 作为理想世界，更系统地刻画理想执行与真实执行之间的关系 [4]。随着研究的深入，模拟范式被不断强化与扩展。最重要的里程碑之一是 2001 年 Ran Canetti 提出的通用可组合性 (Universal Composability, UC) 框架 [5]，它把理想/真实的模拟思想提升为一个可组合的证明体系，使得在任意上下文中安全保持不变成为可能。UC 框架引入了更强的理想功能与环境模型，并指出了在没有适当设置 (如公共参考字符串、证书注册局或可信设定) 下的某些不可能性结果。Lindell 系统性地阐述了如何进行模拟证明 [6]。

与基于游戏的定义 (例如 IND-CPA、EUF-CMA 等) 相比，基于模拟的定义具有以下显著特点：

- 全局语义保证：模拟定义直接比较敌手所见的全部视图，能够一次性捕捉多轮交互的复合泄漏，适合需要强语义保证的高阶原语与复合协议。
- 可组合性 (在 UC 或其变体下)：若协议在可组合框架下被证明安全，则可安全地作为子协议嵌入更大系统。
- 证明成本与假设：模拟式证明往往需要构造强模拟器 (有时是重饶式的或依赖黑盒/白盒策略)，证明复杂度和构造难度通常高于基于游戏的归约。

尽管强大，模拟范式也存在实际与理论上的限制：

- 强定义带来的不可能性：在没有额外设置的情况下，某些理想化安全目标不可实现，导致必须引入可信初始化 (setup) 或对功能进行弱化；
- 模拟器构造难度：对于某些协议，存在证明上的技术障碍 (例如需要重饶敌手)，构造高效模拟器并非总是可行；
- 性能与工程折中：为获得可组合性或更强的模拟性质，通常需要更多的密码学假设或更重的运行开销。

1.2 内容安排

基于上述背景，本文的目标是系统梳理基于模拟的安全范式。具体内容包括：

- 阐明理想/真实世界的核心概念与定义，并通过示例给出和分析基于模型的安全性定义及其内涵；
- 力图用一个统一的框架来描述几个典型密码算法、协议的基于模型的安全性定义；
- 用几类经典原语（公钥加密、承诺、密钥交换、零知识证明、Hybrid）作为案例，逐一给出系统模型、安全模型、方案构造与基于模拟的安全证明；
- 尝试给出简单易懂的通用可组合性（UC）实例。

第 2 节给出一些必备的基础知识；第 3 节将分析基于模拟的安全性定义；以公钥加密为 warmup 的实例在第 4 节给出；第 5 节尝试分析承诺协议，开始给出完整实例并证明安全性，随后分别讨论零知识、密钥交换等原语，最后讨论可组合性扩展问题。

2 基础知识

首先给出一些基础知识，包括密码学安全性证明的基本概念、基于游戏的安全性定义与证明方法，以及基于模拟的安全性定义的核心内涵。这些内容为后续章节中具体协议的安全证明提供必要的理论工具和分析框架。

2.1 密码学安全性证明的基本概念

密码学安全性证明是为密码方案提供形式化保证的核心工具，它不依赖于直觉性的描述，而是用严格的数学语言定义“安全”的含义。

一个完整的安全证明通常包含以下关键要素：

- **安全参数 κ** ：用于量化算法的输入规模和安全强度，随着 κ 增大，安全性应当提升。通常用 1^κ 表示安全参数，其含义是 κ 个 1 组成的字符串，放在算法输入中，表示其输入长度为 κ 。
- **敌手模型**：明确敌手的能力边界，例如是否能控制网络、阅读或篡改消息、收买参与方等。在定义中刻画敌手模型就是建模敌手的能力。
- **安全目标**：采用可验证的数学性质描述方案应满足的安全属性，如机密性、完整性、认证性或零知识性。
- **复杂性假设**：将协议的安全性归约到公认的困难问题或者已证明的安全性上，例如离散对数、DDH、RSA 或签名不可伪造性等。
- **规约**：将一个复杂问题的安全性转化为一个“已知”问题的安全性。例如，将 RSA 加密算法的安全性规约到大整数分解问题的困难性上。

在密码学中，安全性的衡量不仅仅是“敌手能否成功”，而是要求敌手的成功概率随安全参数增长而衰减为**可忽略函数**。具体来说，函数 $\text{negl}(\kappa)$ 当且仅当对任意多项式 $p(\kappa)$ ，存在足够大的 κ 使得

$$\text{negl}(\kappa) < \frac{1}{p(\kappa)}.$$

这种定义保证了攻击成功概率在实际可计算范围之外。

正式证明通常采用“游戏”或“模拟”的方式，将协议执行过程抽象为一种交互过程，并严格说明敌手与协议参与方之间的信息流与步骤。

有必要特别指出几个常见的词汇翻译方法：

- **oracle**：谕言机，表示“神谕”的意思 [7]。

- **corrupted**: 在本文中翻译成“被收买”，因为常见翻译“腐化”不包含被动语态，更像是一种状态。
- **reduction**: 规约，表示将一个复杂问题转化为一个“已知”问题。
- **primitive**: 原语，表示最基本的密码学算法、部件。

下面给出几个定义。

定义 2.1 (概率多项式时间 (PPT) 算法). 一个算法 $\mathcal{A}$ 是概率多项式时间的，如果存在一个多项式 $p(\cdot)$ ，使得对于所有输入长度 κ ，算法 $\mathcal{A}$ 在输入 1^κ 上的运行时间不超过 $p(\kappa)$ 。

定义 2.2 (可忽略函数). 函数 $\text{negl} : \mathbb{N} \rightarrow \mathbb{R}$ 是可忽略的，如果对于每个多项式 $p(\cdot)$ ，存在一个 κ_0 ，使得对于所有 $\kappa > \kappa_0$ ，都有 $\text{negl}(\kappa) < \frac{1}{p(\kappa)}$ 。

定义 2.3 (区分分布 P_0 与 P_1 的攻击游戏 [8]). 给定有限集合 $\mathcal{R}$ 上的两个概率分布 P_0, P_1 ，以及敌手 $\mathcal{A}$ ，我们定义两个实验：实验 0 与实验 1。对 $b = 0, 1$ ，定义实验 b 如下：

实验 b :

- 挑战者按如下方式计算 x :

$$x \xleftarrow{R} P_b$$

并将 x 发送给敌手。

- 敌手接收 x 后进行计算，输出一个比特 $\hat{b} \in \{0, 1\}$ 。

对 $b = 0, 1$ ，记 W_b 为“敌手 $\mathcal{A}$ 在实验 b 中输出 1”这一事件。我们定义敌手 $\mathcal{A}$ 针对分布 P_0, P_1 的区分优势为：

$$\text{Distadv}[\mathcal{A}, P_0, P_1] := |\Pr[W_0] - \Pr[W_1]|.$$

定义 2.4 (计算不可区分 [8]). 若对所有高效敌手 $\mathcal{A}$ ，区分优势 $\text{Distadv}[\mathcal{A}, P_0, P_1]$ 均为可忽略函数，则称分布 P_0 与 P_1 是计算不可区分的。

定义 2.5 (统计距离 [8]). 设 P_0 与 P_1 是有限集合 $\mathcal{R}$ 上的两个概率分布，则二者的统计距离定义为：

$$\Delta[P_0, P_1] := \frac{1}{2} \sum_{r \in \mathcal{R}} |P_0(r) - P_1(r)|$$

定义 2.6 (统计不可区分 [8]). 设 P_0 与 P_1 是有限集合 $\mathcal{R}$ 上的概率分布。若二者的统计距离 $\Delta[P_0, P_1]$ 为可忽略函数，则称 P_0 与 P_1 是统计不可区分的。

2.2 基于游戏的安全性证明及实例

基于游戏的安全性证明将安全属性描述为敌手与一个挑战者之间的交互游戏。敌手的成功概率被定义为其在游戏中获胜的概率，安全性则要求该成功概率在合理假设下可忽略。

2.3 安全模型实例：IND-CPA

一个经典的加密安全性目标是选择明文攻击下的不可区分性（IND-CPA）。其游戏定义如下：

1. 初始化阶段：挑战者生成密钥 $k \leftarrow \mathcal{K}$ ，将公钥或密钥信息保留，向敌手 $\mathcal{A}$ 公开必要的公共参数。
2. 查询阶段：敌手 $\mathcal{A}$ 可多次提交明文查询 m ，挑战者返回相应的密文 $c = \text{Enc}_k(m)$ 。
3. 挑战阶段：敌手提交两个等长明文 (m_0, m_1) ，挑战者随机选取比特 $b \leftarrow \{0, 1\}$ ，返回挑战密文 $c^* = \text{Enc}_k(m_b)$ 。
4. 猜测阶段：敌手输出猜测 b' ，若 $b' = b$ 则敌手获胜。

敌手相对于该游戏的优势定义为：

$$\text{Adv}_{\mathcal{A}}^{\text{IND-CPA}}(\kappa) = \left| \Pr[b' = b] - \frac{1}{2} \right|.$$

定义 2.7 (IND-CPA 安全性). 一个加密方案 $\mathcal{E}$ 满足 IND-CPA 安全性，如果对任意 PPT 敌手 $\mathcal{A}$ ，在上述游戏中获胜的优势为可忽略函数：

$$\text{Adv}_{\mathcal{A}}^{\text{IND-CPA}}(\kappa) \leq \text{negl}(\kappa)$$

2.3.1 实例：基于伪随机函数的随机化对称加密

首先需要确定的是不存在加密算法为确定性的 CPA 安全加密方案（有状态加密方案除外）。因为对于随机选取的明文 $m, m' \in \mathcal{M}$ ，攻击者总能轻易区分密文对 $(\text{Enc}(k, m), \text{Enc}(k, m))$ 和 $(\text{Enc}(k, m), \text{Enc}(k, m'))$ 。事实上，所有满足 CPA 安全的加密方案，其加密算法都是随机化的。

考虑如下随机化对称加密方案 $\mathcal{E} = (\text{Gen}, \text{Enc}, \text{Dec})$ ：

- $\text{Gen}(1^\kappa)$ ：随机生成密钥 $k \leftarrow \{0, 1\}^\kappa$ 。
- $\text{Enc}_k(m)$ ：对于 $m \in \mathcal{M} = \{0, 1\}^*$ ，随机选择 $r \leftarrow \{0, 1\}^\kappa$ ，输出密文

$$c = (r, F_k(r) \oplus m),$$

其中 F_k 是带密钥的伪随机函数，定义为 $F_k : \{0, 1\}^\kappa \times \{0, 1\}^* \rightarrow \{0, 1\}^*$ 。

- $\text{Dec}_k((r, s))$: 计算 $m = F_k(r) \oplus s$ 并返回明文。

该方案使用随机数 r 作为一次性随机化向量, 保证相同明文每次加密结果不同, 从而避免重复明文泄露。此时, 若 F_k 是安全的伪随机函数, 则方案可以满足 IND-CPA 安全。

我们下面证明若存在对上述方案具有非忽略优势的 IND-CPA 敌手 $\mathcal{A}$, 则可以构造一个伪随机函数区分器 $\mathcal{D}$, 攻破 F_k 的安全性。

定理 2.8. 如果 F 是一个安全的伪随机函数, 则上述加密方案 $\mathcal{E}$ 满足 IND-CPA 安全性。

证明. 构造区分器 $\mathcal{D}$:

1. $\mathcal{D}$ 从伪随机函数挑战中获得一个查询预言机 $\mathcal{O}(\cdot)$, 它要判断该接口是一个真实的伪随机函数 F_k 还是一个真正的随机函数。
2. $\mathcal{D}$ 运行敌手 $\mathcal{A}$, 并在 $\mathcal{A}$ 的任何密文查询 m 时:
 - 随机选择 $r \leftarrow \{0, 1\}^\kappa$;
 - 令 $s = \mathcal{O}(r) \oplus m$;
 - 返回密文 (r, s) 给 $\mathcal{A}$ 。

3. 当 $\mathcal{A}$ 提出挑战对 (m_0, m_1) 时, $\mathcal{D}$ 依然随机选择 $r^* \leftarrow \{0, 1\}^\kappa$, 构造

$$c^* = (r^*, \mathcal{O}(r^*) \oplus m_b)$$

并将其交给 $\mathcal{A}$ 。

4. 最终, $\mathcal{D}$ 输出 $\mathcal{A}$ 的猜测 b' 作为自身的判别结果。

分析:

- 若 $\mathcal{O}(\cdot)$ 是真实的伪随机函数 $F_k(\cdot)$, 则 $\mathcal{D}$ 为 $\mathcal{A}$ 提供的密文分布与真实加密方案完全一致, 故

$$\Pr[\mathcal{D} \text{ 输出 } 1 \mid \mathcal{O} = F_k] = \Pr[b' = b].$$

- 若 $\mathcal{O}(\cdot)$ 是真正的随机函数, 则对每个用于加密的随机 r , 值 $\mathcal{O}(r)$ 是独立且均匀的二进制串, 因此挑战密文中的掩码部分

$$\mathcal{O}(r^*) \oplus m_b$$

对 b 来说是信息上不可区分的。此时

$$\Pr[\mathcal{D} \text{ 输出 } 1 \mid \mathcal{O} \text{ 随机}] = \frac{1}{2}.$$

因此, $\mathcal{D}$ 的区分优势满足:

$$\text{Adv}_{\mathcal{D}}^{\text{PRF}}(\kappa) = \left| \Pr[b' = b] - \frac{1}{2} \right| = \text{Adv}_{\mathcal{A}}^{\text{IND-CPA}}(\kappa).$$

如果 $\mathcal{A}$ 的 IND-CPA 优势为不可忽略的函数, 则 $\mathcal{D}$ 对 PRF 的区分优势也为不可忽略的函数, 这将攻破 F 的伪随机安全性。于是该加密方案在伪随机函数假设下满足 IND-CPA 安全。 $\square$

通过这个实例我们可以看到, 基于游戏的安全性证明既能给出明确的攻击模型, 又能够将具体方案的安全性归约到更基本的密码学假设上。

3 基于模拟的安全性定义

基于模拟的安全性形式化定义思路可概括为：在“真实世界”中针对协议发起的任意攻击，都等价于“理想世界”中某一类攻击，而理想世界不存在任何可造成实际危害的攻击行为。在理想世界中，协议借助可信方完成执行，所有参与方（无论诚实方还是被收买方）向可信方提交各自输入，并从可信方处获取分配给自身的输出，且可信方本身无法被收买。

形式化定义的构造流程可总结为：

- 首先，刻画真实世界协议的完整执行细节，涵盖敌手所具备的攻击能力与通信信道的各项特性。
- 其次，刻画理想世界的执行流程，包含负责功能实现的可信方的完整行为逻辑。
- 最后，**显示地**给出安全性的内涵，即对真实世界内任意高效敌手 $\mathcal{A}$ ，在理想世界中都存在一个与之“等价”的高效敌手 $\mathcal{S}$ （通常称作模拟器）。由于理想世界不存在可行攻击，因此真实世界同样不存在能够造成危害的攻击。

以多方安全函数计算为例，隐私性、完备性、输入独立性这些直观安全属性均可由这样的定义所隐含得出。这是因为，上述安全性质直观上在理想世界中天然成立，又因真实世界与理想世界是等价（计算/统计不可区分）的，因此这些性质在真实世界中同样成立。

基于模拟的安全性以真实世界和理想世界无法区分的形式间接定义。那么，我们自然会问这样一个问题：为什么不直接通过定义真实世界不存在攻击而定义安全性呢？

Yehuda Lindell 给出了一个直观的回答：以加密为例，问题的核心难点在于，我们根本无法精准形式化“不会泄露任何信息”这一概念。假设我们试图规定，敌手拿到密文后，无法推导出明文的任何信息。但如果敌手本身事先就掌握了关于明文的先验信息，又该如何界定？举个例子：敌手预先就知道明文是英文文本。显然，这类信息和加密方案本身的安全性毫无关联——因为敌手在获取密文之前、完全脱离密文就能得到该信息。而基于模拟的安全定义恰好可以严谨、精确地刻画这一核心思想：**我们称一套加密方案是安全的，当且仅当敌手最终能提取（输出）的全部信息，仅仅来源于其自身已有的先验知识。**如果一个未获取任何密文的敌手，能够输出与拿到密文的敌手完全相同的信息分布，就说明密文没有带来任何额外增量信息，上述安全条件成立 [6]。

遵循 Dan Boneh 的思路，我们通过一个 MPC 协议来描述真实世界和模拟世界的定义和逻辑 [8]。

3.1 真实协议和其执行过程

首先,我们详细地描述多方(N 方)协议及其执行过程。系统中有 N 个参与方 $P_1, \dots, P_N$, 每个参与方独立运行协议 Π 。我们假定每个参与方 P_i 知晓自身的编号 i 。系统中存在敌手 $\mathcal{A}$ (当前假定其为恶意敌手)。

若 $P_1, \dots, P_N$ 中存在被收买的参与方, 我们直接将被收买方的行为纳入敌手 $\mathcal{A}$ 的行为逻辑中。该建模方式刻画了如下现实: 被收买的参与方之间可以相互串通, 也能与外部攻击者勾结。因此将所有腐化行为统一抽象为单一实体 $\mathcal{A}$ 会更加简便。

我们假定所有参与方通过异步通信信道 $\mathcal{C}$ 交互。一般假设 $\mathcal{C}$ 是安全的点对点信道, 每条点对点信道同时保障消息的隐私性与完整性。我们将底层实现全部抽象, 直接把 $\mathcal{C}$ 建模为具备物理安全性的点对点信道, 即便信道本身安全, 敌手仍能通过信道传输的消息获取部分信息、并对消息施加一定控制, 具体规则如下:

- 消息发送时, 敌手能够获知消息发送事件、消息长度、发送方身份以及目标接收方。该设定刻画了两类现实特性: 一是加密方案会泄露密文长度相关信息; 二是在真实网络部署中, 敌手能够观测消息的发送者与接收者。
- 消息的送达时机与是否送达由敌手决定。该设定对应异步通信信道 $\mathcal{C}$ 的特性: 信道不保证消息一定送达、也不保证送达时延, 因此我们将消息调度权交由敌手掌控。
- 敌手无法获取消息的其余信息, 也不能篡改消息、伪造消息发送者身份, 更不能将消息转发给目标接收方以外的其他参与方。

整个模型中还有一个核心组件, 我们称之为**环境**。环境负责向诚实参与方提供输入、接收诚实参与方输出; 同时由环境判定哪些参与方被收买、哪些保持诚实。协议执行过程中, 环境还可与敌手 $\mathcal{A}$ 协同交互。我们用符号 $\mathcal{Z}$ 表示环境。

图2所示为上述 MPC 协议的真实执行和其基本拓扑:

- 在图中, 有四个参与方 P_1, P_2, P_3, P_4 , 但假定 P_3 和 P_4 被收买, 并在图中“吸收”到了敌手 $\mathcal{A}$ 中。
- 通信网络 $\mathcal{C}$ 包含 4 条线路, 原本分别对接 4 个参与方; 但由于参与方 P_3 、 P_4 已包含在敌手 $\mathcal{A}$, 他们的线路将直接连通至 $\mathcal{A}$ 。基于此设定, 敌手 $\mathcal{A}$ 若想向 P_1 发送一条看似来自 P_3 的消息, 只需通过标号为 3 的线路传输该消息即可。同理, P_1 发给 P_3 的消息也会沿这条线路抵达 $\mathcal{A}$ 。我们将这类线路称为 $\mathcal{C}$ -I/O 线路 ($\mathcal{C}$ -I/O wires)。
- 敌手 $\mathcal{A}$ 与网络 $\mathcal{C}$ 之间还存在一条控制线路, 我们称之为 $\mathcal{C}$ -控制线。敌手 $\mathcal{A}$ 可通过这条控制线接收来自网络 $\mathcal{C}$ 的“泄露消息”, 这类消息会向敌手泄露诚实参与方所发送

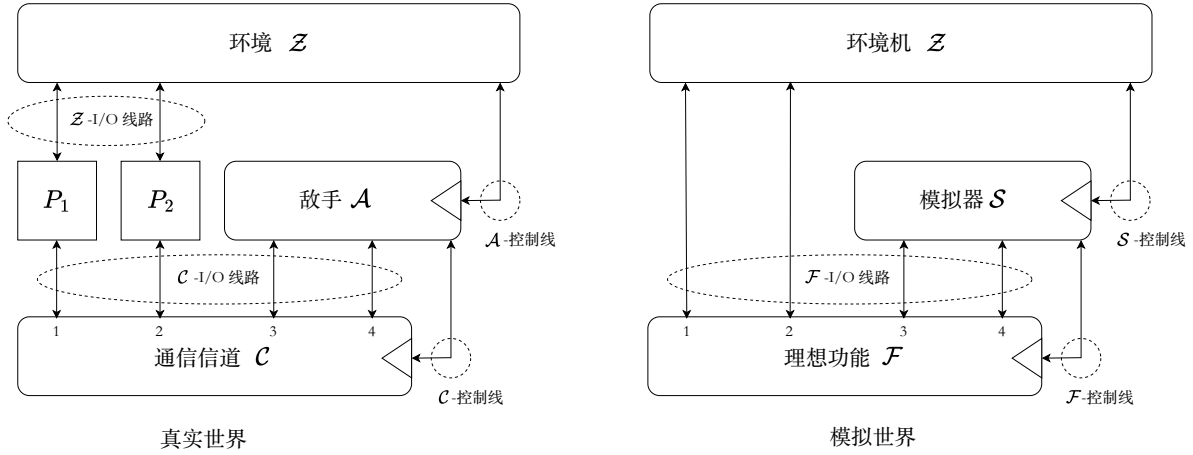


图 2: UC 框架下的 MPC 协议真实世界 vs 模拟世界 [8]

协议消息的部分信息。同时，敌手 $\mathcal{A}$ 也能经由该控制线向网络 $\mathcal{C}$ 发送“控制消息”，以此指令网络 $\mathcal{C}$ 何时向诚实参与方交付协议消息。

- 模型中还包含环境机 $\mathcal{Z}$ ，环境机通过线路与诚实参与方 P_1 、 P_2 相连，可经由这些线路输入协议的输入、接收协议的输出，我们将这类线路称作 $\mathcal{Z}$ -I/O 线路。环境机 $\mathcal{Z}$ 与敌手 $\mathcal{A}$ 之间同样设有一条控制线路，称为 $\mathcal{A}$ -控制线，二者可通过该线路直接通信。其核心逻辑为：环境机 $\mathcal{Z}$ 可向敌手 $\mathcal{A}$ 发送“控制消息”，用以指导敌手后续的行为；同时环境控制线路也能接收来自敌手的“泄露消息”，该消息代表泄露至环境控制线路的各类信息。

备注 3.1 (环境的角色). 顾名思义，环境机用于对协议执行所处的外部环境进行建模。实际场景中，某一协议可作为子协议嵌入更大的上层协议，而上层协议的所有其余组件都会被抽象封装，统一由 $\mathcal{Z}$ 这一实体建模。由于允许环境在协议执行过程中与敌手交互，我们能够刻画子协议与上层协议之间所有可能发生的交互行为。基于这一设定，我们可以证明关键的组合定理 (composition theorems)，其直观含义为：若一个协议本身是安全的，那么无论将它作为子协议嵌入任意上层协议，或是并发运行该协议的多个实例，它都能维持安全性。正因这些组合定理成立，图2所介绍的安全模型被称为**通用可组合框架**。

真实协议执行要点：

- 由于模拟范式的核心思想是将协议的参与方建模为交互式图灵机 (Interactive Turing Machines, ITM)，因此在协议的执行中，用机器来代表包括环境、敌手在内的各个参与方。相应地，网络的通信被抽象为机器之间的消息传递。图2中刻画真实协议执行模型隐含着多机器之间的并发。意思是说，实际上敌手可以掌控各台机器计算操作的交错调度顺序。

- 环境机 $\mathcal{Z}$ 开始执行协议后，确定了哪些参与方被收买¹，这些信息被写入仅由 $\mathcal{C}$ 和 $\mathcal{A}$ 可见的特殊磁带 (tape)，其对诚实参与方不可见，这里刻画的事实是：诚实参与方不知道哪些参与方被收买了。
- 环境机 $\mathcal{Z}$ 停机则协议停机，在停机前，环境机 $\mathcal{Z}$ 在一个特殊的输出带 (tape) 上输出一个 bit；
- 敌手和诚实参与方之间不能直接交互，所有的交互都要经过安全信道间接完成。如果考虑非安全信道，那么需要定义额外的敌手来建模。
- 定义环境 $\mathcal{Z}$ 是行为良好的 (well behaved)，当且仅当其运行时间可由安全参数的某个多项式严格上界约束（该多项式可与环境 $\mathcal{Z}$ 自身相关）。
- 称敌手 $\mathcal{A}$ 与协议 Π 相容 (compatible with)²，当且仅当对任意行为良好的环境 $\mathcal{Z}$ ，所有诚实参与方 P_i 与敌手 $\mathcal{A}$ 的总运行时间，以压倒性概率被某个多项式约束；该多项式由协议 Π 与敌手 $\mathcal{A}$ 决定，与环境 $\mathcal{Z}$ 无关，多项式的自变量包含安全参数、以及环境经由 $\mathcal{Z}$ -I/O 线路、 $\mathcal{A}$ -控制线所发送全部消息的总长度。
- 基于上述定义，若 $\mathcal{Z}$ 为行为良好的，且敌手 $\mathcal{A}$ 与协议 Π 相容，则所有机器的整体运行时间将以压倒性概率被某个多项式约束；该多项式由协议 Π 、敌手 $\mathcal{A}$ 、环境 $\mathcal{Z}$ 三者共同决定，自变量为安全参数。
- 若平凡敌手与协议 Π 相容，则称协议 Π 是**高效协议**。

3.2 理想世界和其执行过程

如图2所示，相对于真实世界，理想世界定义的变化是：

- 理想世界存在一个不同的敌手 $\mathcal{S}$ ，称为模拟器；
- 定义一个理想功能（或称为函数，ideal functionality） $\mathcal{F}$ ，由一个绝对可信的第三方 (Trusted Party, TTP) 实现。 $\mathcal{F}$ 定义了协议安全合规的理想行为，其具体内容由协议的目标决定。例如，在一个多方安全函数计算的 MPC 中， $\mathcal{F}$ 的功能就是：接收各方输入，计算目标函数，并将结果返回给各方。在一个零知识证明中， $\mathcal{F}$ 的功能就是：接收证明者的证据和验证者的挑战，验证证据的有效性，并返回验证结果。

¹目前仅假设静态敌手

²“相容”、“兼容”、“可容许的”等等翻译缺乏统一的说法，这个问题后面专门讨论3.4。

- 可以看出，诚实参与方在图中消失了，因为他们的从环境机 $\mathcal{Z}$ 收到的输入消息直接转交给 $\mathcal{F}$ ，而 $\mathcal{F}$ 的输出直接返回给环境机 $\mathcal{Z}$ 。因此，理想世界中不存在任何诚实参与方的计算过程。

理想协议执行要点：

- 环境机 $\mathcal{Z}$ 开始执行协议后，确定了哪些参与方被收买，这些信息也是被写入仅由 $\mathcal{F}$ 和 $\mathcal{S}$ 可见的特殊磁带 (tape)，其对诚实参与方不可见；
- 环境机 $\mathcal{Z}$ 停机则协议停机，在停机前，环境机 $\mathcal{Z}$ 在一个特殊的输出带 (tape) 上输出一个 bit；
- 环境机 $\mathcal{Z}$ 可经由 $\mathcal{F}$ -I/O 线路向任意诚实参与方 P_i (在图2中，诚实参与方均被省略) 传递协议输入，该输入会被直接转发至理想功能 $\mathcal{F}$ 。环境机 $\mathcal{Z}$ 可经由 $\mathcal{S}$ -控制线向模拟器 $\mathcal{S}$ 发送控制消息。
- 模拟器 $\mathcal{S}$ 可经由某条对应被收买参与方的 $\mathcal{F}$ -I/O 线路，向理想功能 $\mathcal{F}$ 发送协议输入；也可经由 $\mathcal{F}$ -控制线，向 $\mathcal{F}$ 发送控制消息。
- 模拟器 $\mathcal{S}$ 可经由模 $\mathcal{S}$ -控制线，向环境机 $\mathcal{Z}$ 传递泄露消息。
- 理想功能 $\mathcal{F}$ 可执行下述操作之一：
 1. 经由某条对应诚实参与方的 $\mathcal{F}$ -I/O 线路，向环境机 $\mathcal{Z}$ 输出协议输出；
 2. 经由某条对应被腐化参与方的 $\mathcal{F}$ -I/O 线路，向模拟器 $\mathcal{S}$ 输出协议输出；
 3. 经由 $\mathcal{F}$ -控制线，向模拟器 $\mathcal{S}$ 传递泄露消息。

3.3 真实世界 vs 理想世界

基于模拟的安全的本质是用理想世界的“天然安全”，反证真实世界的“协议安全”。两个世界的定义对比如下：

表 1: 真实世界与理想世界的对比

维度	真实世界 (Real World)	理想世界 (Ideal World)
参与方	诚实协议执行方 + 真实敌手 $\mathcal{A}$ (吸收了被收买方)	实现 $\mathcal{F}$ 的 TTP (隐含了诚实协议执行方) + 模拟器 $\mathcal{S}$ (理想敌手)
通信环境	公开/安全信道，根据不同的敌手建模	理想安全信道，仅通过 TTP 交互
敌手行为	监听、篡改、丢弃消息、收买参与方	无恶意敌手， $\mathcal{S}$ 仅负责复刻敌手视图
环境	提供运行环境	试图区分所处世界

3.4 基于模拟的安全性定义

以一个多方安全函数计算协议 Π 为例，我们正式给出其基于模拟的安全性定义。该定义是密码学中最严格的安全性定义之一，要求协议在真实世界中执行时，敌手所能获取的信息与在理想世界中由模拟器生成的视图完全不可区分。

下面我们给出协议安全性的形式化定义。

- 记 $\text{View}_{\mathcal{Z}}^{\text{Real}}[\Pi, \mathcal{A}]$ 为真实世界执行对应的概率分布，该分布刻画环境 $\mathcal{Z}$ 在与协议 Π 、敌手 $\mathcal{A}$ 完整交互过程中所能观测到的全部信息，即视图。其随机性来自于可获取的输入、交互信息与最终输出。
- 记 $\text{View}_{\mathcal{Z}}^{\text{Ideal}}[\mathcal{F}, \mathcal{S}]$ 为理想世界执行对应的概率分布，该分布刻画环境 $\mathcal{Z}$ 在与理想功能 $\mathcal{F}$ 、模拟器 $\mathcal{S}$ 完整交互过程中所能观测到的全部信息，即视图。该分布的随机性来自于可获取的输入、交互信息与最终输出。

为简化本节记号，对任意随机变量 X, Y ，我们使用记号 $X \approx Y$ 表示 X 与 Y 是统计不可区分的。若 X, Y 均为 0/1 布尔随机变量，则该条件等价于 $|\Pr[X = 1] - \Pr[Y = 1]|$ 是可忽略函数。

定义 3.2 (基于模拟的安全 [8] (修订)). 设敌手 $\mathcal{A}$ 与协议 Π 相容。若存在一个与理想功能 $\mathcal{F}$ 相容的模拟器 $\mathcal{S}$ (模拟器可依赖敌手 $\mathcal{A}$)，使得对任意行为良好的环境 $\mathcal{Z}$ ，均满足：

$$\text{View}_{\mathcal{Z}}^{\text{Real}}[\Pi, \mathcal{A}] \approx \text{View}_{\mathcal{Z}}^{\text{Ideal}}[\mathcal{F}, \mathcal{S}]$$

则称协议 Π 能够抵御敌手 $\mathcal{A}$ 、安全实现理想功能 $\mathcal{F}$ 。

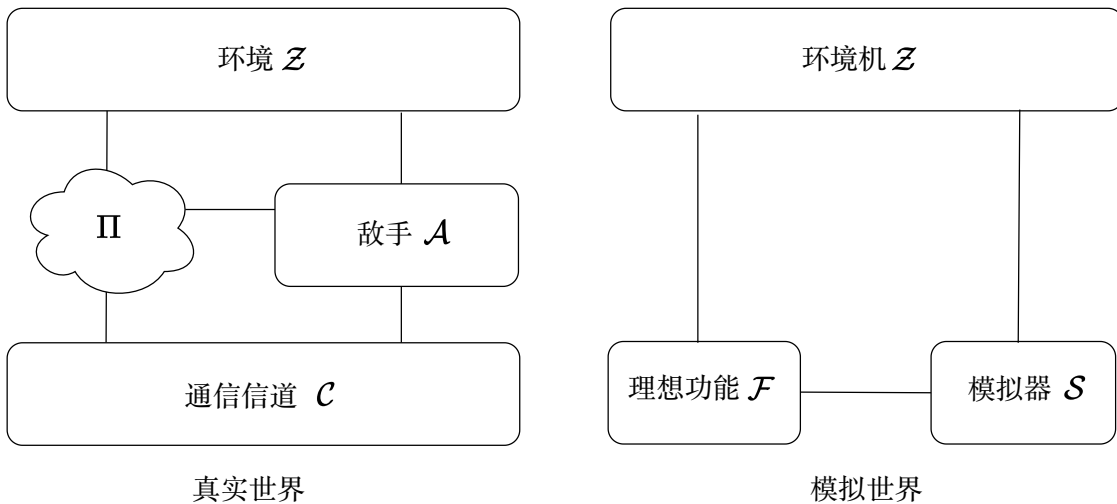


图 3: 定义3.2中的真实世界 vs 模拟世界

定义3.2中的真实世界和模拟世界如图3所示。

下面给出面向所有敌手的安全性定义，该定义完整刻画了安全协议的核心内涵。

定义 3.3 (基于模拟的安全 (所有敌手) [8] (修订)). 若对每一个与协议 Π 相容的敌手 $\mathcal{A}$, 协议 Π 都能抵御 $\mathcal{A}$ 、安全实现理想功能 $\mathcal{F}$, 则称协议 Π 安全实现理想功能 $\mathcal{F}$ 。

展开该定义可得等价表述: 协议 Π 安全实现理想功能 $\mathcal{F}$, 当且仅当对任意与 Π 相容的敌手 $\mathcal{A}$, 均存在一个与 $\mathcal{F}$ 相容的模拟器 $\mathcal{S}$ (模拟器可依赖敌手 $\mathcal{A}$), 使得对任意行为良好的环境 $\mathcal{Z}$, 满足 $\text{View}_{\mathcal{Z}}^{\text{Real}}[\Pi, \mathcal{A}] \approx \text{View}_{\mathcal{Z}}^{\text{Ideal}}[\mathcal{F}, \mathcal{S}]$ 。

不难看出, 该形式化定义精准刻画了安全性的核心含义, 即任意敌手 $\mathcal{A}$ 攻击真实协议 Π 所能造成的破坏, 不会超过另一模拟器 $\mathcal{S}$ (可由 $\mathcal{A}$ 构造得到) 攻击理想协议所能造成的破坏。针对多方安全函数计算协议, 对应的理想功能为 $\mathcal{F}_{\text{sfe}}$, 可以证明该安全定义能够同时隐含着隐私性、完备性与输入独立性。

3.4.1 定义3.3的进一步理解

密码方案 (特别是公钥密码) 的研究范式告诉我们, 一个完整的方案描述至少要包括系统模型、安全模型³、方案构造以及安全性证明⁴等四个部分。

以实现多方安全函数计算的协议 Π 为例, 系统模型即为 N 个参与方 $P_1, \dots, P_N$ 共同计算一个函数 f 。其安全目标包含:

- 隐私性 (privacy): 任何参与方都无法获取其他参与方的输入信息;
- 可靠性 (soundness): 诚实参与方一定计算正确的输出;
- 输入独立性 (input independence): 所有参与方的输入都独立于其他参与方的输入。

在基于游戏的安全性定义中, 我们通常可以看到显式的安全模型描述 (如 IND-CPA、EUF-CMA 等, 可参考定义2.7), 但在基于模拟的安全性定义中, 安全性概念 (notion) 往往被隐含。例如, 我们常读到形如 “协议 Π 安全实现理想功能 $\mathcal{F}$ ”、“存在一个模拟器 $\mathcal{S}$ 使得...” 的安全性定义。这样的隐含定义对于初学者而言, 无异于多了一层理解上的困难。因此, 有必要反复强调其内涵, 并指引学生遵循密码方案的研究范式。

正如本章一开始所述, 基于模拟的安全性定义的核心内涵是: 真实世界内任意高效敌手 $\mathcal{A}$, 在理想世界中都存在一个与之 “等价” 的高效敌手 $\mathcal{S}$ 。由于理想世界不存在可行攻击, 因此真实世界同样不存在能够造成危害的攻击。

³亦即安全性定义、威胁模型 (非形式化)、敌手模型等, 是为了实现预定安全目标而进行的形式化建模。相当于定义一个标准、标杆或尺子。

⁴亦即安全性分析。主要的任务就是用自己定义的标准、标杆、尺子去衡量构造的方案, 论述其满足定义。

我们还是以实现多方安全函数计算的协议 Π 为例，来具体分析定义3.3中的各个元素的含义，以及该定义的内涵。对应的理想功能为 $\mathcal{F}_{\text{sfe}}$ ，由一个 TTP 实现，其功能就是接收各方输入，计算目标函数 f ，并将结果返回给各方（可参考图2和图3）。因此， $\mathcal{F}_{\text{sfe}}$ 是完全安全和可信的。安全意味着他不可能被收买，可信意味着他一定会诚实地执行函数 f 的计算并返回结果。

进一步， $\mathcal{F}_{\text{sfe}}$ 得到了诚实参与方的输入并实现了计算功能，将结果返回给环境 $\mathcal{Z}$ 和模拟器 $\mathcal{S}$ 。 $\mathcal{F}_{\text{sfe}}$ 不可能被收买就意味着模拟器得不到诚实参与方的输入，这就刻画了输入隐私性（privacy）。此刻必须强调的是，在考虑攻击输入隐私性的时候，敌手由模拟器 $\mathcal{S}$ 所隐含。

类似地， $\mathcal{F}_{\text{sfe}}$ 的计算结果是正确的，这就刻画了协议的可靠性（soundness）。可靠性意味着诚实参与方一定计算得到正确的输出，因此此刻攻击可靠性的敌手（同样由模拟器 $\mathcal{S}$ 所隐含）无法通过篡改诚实参与方的输入或输出等方式来破坏协议的正确性。

同样， $\mathcal{F}_{\text{sfe}}$ 的输出不依赖于被收买参与方的输入，这就刻画了输入独立性（input independence）。

这种用一个安全性定义去刻画多个安全属性在基于模拟的安全性定义中似乎是一个常规操作。而事实上，我们在基于游戏的安全性定义中也常常看到这种情况，例如匿名 IBE 将语义安全性和匿名性同时定义。

备注 3.4 (关于“相容”的讨论). 在定义3.3中，我们看到“与协议 Π 相容”的描述，其英文表述为“be compatible with”，其含义是指敌手的通信行为、计算能力限制与协议本身的消息规则、安全约束完全匹配，不会引入协议未定义的非常规交互方式。

在密码学的形式化安全模型中，通信协议并非一系列抽象的流程描述，而是会被严格形式化为一组交互图灵机（ITM）。具体来说，每一个协议参与方、协议子组件、理想安全功能，都会被建模为一台独立的交互图灵机。这类机器的形式化规格中，会明确界定三类必须严格遵守的技术规则：

通信身份规则：给每台机器分配独一无二的静态通信身份 ID，在整个协议执行周期内不会变更。

通信对端规则：以“允许发送消息的对端机器 ID + 消息类型”的二元组形式，明确限定该机器能与哪些身份的机器通信，以及可以发送/接收的消息类型。

消息处理规则：严格定义机器收到特定类型消息后的内部状态变更逻辑、消息转发规则、输出计算规则，包括对消息格式、长度、密码学参数的合规性校验逻辑。

从技术实现逻辑上看，敌手的攻击行为要想对协议的安全性产生实际影响，或者说，敌手的攻击行为要想被协议执行所感知，那么该攻击行为在通信模式、消息格式、资源占用方式等维度，必须与协议本身的通信规则、消息处理逻辑及安全约束条件相匹配。所有这一切规则被定义为“相容”。

4 公钥加密

自可证明安全思想诞生以来,加密方案是首个安全性被严格形式化定义的密码原语,其刻画的核心思想是:敌手无法从密文中获取任何关于明文的有效信息。

我们尝试采用基于模拟的安全定义重新剖析经典随机化加密方案的语义安全。直观上,借助模拟安全框架刻画语义安全似乎有点“多此一举”,但我们不妨回归语义安全的敌手模型本身展开分析。回顾定义2.7,在安全游戏中,敌手获胜判定标准为能否区分挑战密文对应的明文是 m_0 还是 m_1 。这个判定条件看似为敌手提供了一个“小窗口”,即敌手仅依托挑战密文 c^* 的信息,判定其由明文 m_0 还是 m_1 加密生成。然而,不难看出标准的语义安全游戏中,敌手能够获取的信息并不局限于最终得到的挑战密文,还包含明文消息长度、安全参数规模、密文输出长度等辅助信息。而且,加密算法属于公开算法,敌手天然具备加密能力,在多项式次数约束下,敌手可自适应选取任意消息执行加密,这一切恰好刻画了敌手除挑战密文以外得到的各类辅助信息(或如前所述为先验信息)。

因此,我们基于模拟安全范式重新解析语义安全定义,就要对其进行一些修订。该修订的思想就是在模拟器生成的模拟视图中,显式地向模拟器提供敌手可获取的全部辅助信息,即安全参数规模、明文长度、密文长度等。

4.1 修订后的加密方案语义安全定义

首先,作如下定义:

- 记 $\text{View}_{\mathcal{Z}}^{\text{Real}}[\mathcal{E}, \mathcal{A}(1^n, E_k(X_n), 1^{|X_n|}, h(1^n, X_n))]$ 为真实世界执行对应的概率分布,该分布刻画环境 $\mathcal{Z}$ 在与加密方案 $\mathcal{E}$ 、敌手 $\mathcal{A}$ 完整交互过程中所能观测到的全部信息,即视图。其随机性来自于可获取的输入、交互信息与最终输出。
- 记 $\text{View}_{\mathcal{Z}}^{\text{Ideal}}[\mathcal{F}, \mathcal{S}(1^n, 1^{|X_n|}, h(1^n, X_n))]$ 为理想世界执行对应的概率分布,该分布刻画环境 $\mathcal{Z}$ 在与理想功能 $\mathcal{F}$ 、模拟器 $\mathcal{S}$ 完整交互过程中所能观测到的全部信息,即视图。其随机性来自于可获取的输入、交互信息与最终输出。

其中, $k \leftarrow G(1^n)$ 为密钥,明文 X_n 的长度依赖安全参数 n ,用函数 $h(1^n, X_n)$ 表示以安全参数和明文为输入的所有辅助信息。

定义 4.1 (基于模拟的公钥加密方案语义安全). 一个随机化对称加密方案 $\mathcal{E} : (G, E, D)$ 满足语义安全性,如果对于任意 PPT 敌手 $\mathcal{A}$,若存在一个模拟器 $\mathcal{S}$ (模拟器可依赖敌手 $\mathcal{A}$),使得对任意行为良好的环境 $\mathcal{Z}$,均满足:

$$\text{View}_{\mathcal{Z}}^{\text{Real}}[\mathcal{E}, \mathcal{A}(1^n, E_k(X_n), 1^{|X_n|}, h(1^n, X_n))] \approx \text{View}_{\mathcal{Z}}^{\text{Ideal}}[\mathcal{F}, \mathcal{S}(1^n, 1^{|X_n|}, h(1^n, X_n))]$$

直观上, 该定义描述了敌手 $\mathcal{A}$ 可以拿到密文 $E_k(X_n)$ 与辅助信息 $h(1^n, X_n)$; 模拟器 $\mathcal{S}$ 仅能获取辅助信息 $h(1^n, X_n)$ 与明文长度 $|X_n|$, 而安全条件要求 $\mathcal{B}$ 的输出的概率分布与 $\mathcal{A}$ 相同。这意味着密文 $E_k(X_n)$ 不会泄露任何关于明文的信息, 敌手 $\mathcal{A}$ 凭借密文能推断出的一切内容, 无密文的模拟器 $\mathcal{S}$ 仅凭辅助信息也能同等推断。敌手 $\mathcal{A}$ 所处的真实世界中, 输入包含密文、辅助信息与明文长度; 而 $\mathcal{S}$ 身处理想世界, 它仅能拿到辅助信息与明文长度, 天然无法接触密文。证明“ $\mathcal{B}$ 的推断能力不弱于 $\mathcal{A}$ ”, 本质就是对真实世界与理想世界做对比分析, 这也是引言中提到的核心思路。

4.2 基于模拟的证明

事实上, 定义2.7给出的经典 IND-CPA 语义安全定义简洁明了。我们的基于模拟的定义看似“多此一举”, 但结合图2给出的框架, 重新对2.3.1给出的随机化对称加密方案进行模拟证明还是具有重要意义的。

既然是思维实验, 就需要千锤百炼。

定理 4.2. 如果 F 是一个安全的 PRF, 那么2.3.1给出的随机化对称加密方案 $\mathcal{E} : (G, E, D)$ 满足定义4.1的模拟安全性, 即对于任意 PPT 敌手 $\mathcal{A}$, 必存在一个模拟器 $\mathcal{S}$, 使得对任意行为良好的环境 $\mathcal{Z}$, 均满足:

$$\text{View}_{\mathcal{Z}}^{\text{Real}}[\mathcal{E}, \mathcal{A}(1^n, E_k(X_n), 1^{|X_n|}, h(1^n, X_n))] \approx \text{View}_{\mathcal{Z}}^{\text{Ideal}}[\mathcal{F}, \mathcal{S}(1^n, 1^{|X_n|}, h(1^n, X_n))]$$

证明. 正如3.4.1指出证明真实世界和理想世界的不可区分被归结为构造一个满足要求的模拟器, 而在很多时候证明的过程也被称为模拟的过程。输入为 $1^n, 1^{|X_n|}, h = h(1^n, X_n)$, 下面我们指出如何构造模拟器 $\mathcal{S}$:

1. 随机选取 $r \leftarrow \{0, 1\}^{|X_n|}$, 计算 $c = (r, r \oplus 0^{|X_n|})$ ($\mathcal{S}$ 必须输入 $1^{|X_n|}$ 才能执行该步骤);
2. 调用敌手 $\mathcal{A}(1^n, c, 1^{|X_n|}, h)$, 直接输出 $\mathcal{A}$ 的返回结果。

可以看出, 在没有密文输入情况下的模拟器 $\mathcal{S}$ 产生的所有输出与敌手 $\mathcal{A}$ 在真实世界中输出的唯一区别在于密文 c 。而安全的 PRF 保证了即便 $\mathcal{S}$ 加密了一个“垃圾”消息 (全 0), 其密文的分布与 $\mathcal{A}$ 的输出密文的分布完全相同。□

5 承诺协议

承诺协议是一个涉及两个参与方（发送方 S 和接收方 R）的两阶段交互协议，其思想可以通过一个通俗的场景来直观理解：想象发送方将一个私密信息写入一张纸条，将纸条放入一个加锁的保密盒子中，再将这个盒子交付给接收方保管。这一动作对应协议的第一阶段——**承诺阶段**：发送方对信息完成“承诺”，接收方拿到盒子，但无法打开它，因此无法获知被承诺的信息内容。在后续的某个预定时间点，协议将进入第二阶段——**揭示阶段**：发送方将打开盒子的钥匙交给接收方，接收方使用钥匙打开盒子、取出纸条，便能验证纸条上的信息确实是发送方最初承诺的内容。从这个直观场景中，我们可以提炼出承诺协议必须满足的两条安全属性：

- **隐藏性 (Hiding)**：在承诺阶段完成后，接收方在没有获取额外信息的前提下，无法获知任何关于发送方所承诺消息的内容。
- **绑定性 (Binding)**：在承诺阶段完成后，发送方无法通过作弊手段，将自己最初的承诺“篡改”为另一个不同的消息；换言之，发送方无法让接收方在揭示阶段接受两个完全不同的有效值，视为对同一个承诺的合法揭示⁵。

需要特别指出的是，在密码学的形式化安全框架中，隐藏性和绑定性这两种安全属性，各自对应着三个严格程度依次递增的安全级别：**完美安全**、**统计安全**与**计算安全**。这三个级别的安全依赖、敌手能力限制以及应用场景，将在本节中给出严格、明确的形式化区分。在实际密码协议设计中，我们往往需要根据业务场景的安全需求，匹配不同安全级别的属性组合。然而，密码学承诺协议中存在一个基础性的“不可能结果”：没有任何一个承诺协议，能够同时满足完美隐藏性和完美绑定性。这一结论直接决定了，在实际应用中，我们必须根据场景的安全侧重点，构造并使用具有互补安全属性组合的承诺协议。基于这一逻辑，我们将重点深入分析两个应用最广泛、安全属性恰好互补的经典承诺协议方案：

1. **Pedersen 承诺协议**：该方案基于离散对数困难假设，是密码学中效率最高、应用最广泛的承诺协议之一。其安全属性组合为 **计算绑定性 + 统计隐藏性**，这意味着它的隐藏性可以抵抗具有无限计算能力的敌手，而绑定性则可以抵抗具有多项式时间计算能力的有效敌手。该方案由 Pedersen 在 1991 年的密码学顶会 CRYPTO 上发表，其最初的设计用途是作为可验证秘密共享协议的基础构件 [9]。
2. **Naor 承诺协议**：该方案基于伪随机生成器这一基础性密码学构件，其安全属性组合为 **统计绑定性 + 计算隐藏性**，与 Pedersen 承诺形成互补。这意味着它的绑定性可以抵抗具有无限计算能力的敌手，而隐藏性可以抵抗多项式时间计算能力的有效敌手。

⁵事实上，在称为“歧义承诺”（equivocal commitment）的原语中，这一条并不严格满足。

该方案由 Naor 在 1991 年的密码学顶级期刊《Journal of Cryptology》上发表，其核心设计目标是基于任何单向函数构造出安全的承诺协议 [10]。

5.1 系统模型

承诺协议是一个典型的两方密码交互协议，其系统模型仅包含两个参与方：

- **发送方（记为 S）**：拥有待承诺的消息，在协议中执行承诺动作，并在协议的揭示阶段打开承诺，向接收方证明其最初承诺的消息值。
- **接收方（记为 R）**：接收发送方发来的承诺数据，在协议的揭示阶段，使用预设的验证逻辑，对发送方揭示的承诺进行合法性校验。

该协议在执行逻辑上明确分为两个顺序执行的核心阶段：承诺阶段和揭示阶段。为了保证协议的安全性，这两个阶段必须在逻辑上严格区分，先完整执行承诺阶段，再执行揭示阶段，不允许出现阶段交织或颠倒的情况。下面我们给出这两个阶段的形式化描述。

定义 5.1 (承诺协议). 一个承诺协议 $\text{Com} = (\text{Commit}, \text{Reveal})$ 由以下两个 PPT 算法构成：

1. **承诺阶段 Commit**：这是一个两方交互算法，其完整的执行逻辑为：发送方 S 将待承诺的消息 $v \in \mathcal{V}$ 作为输入，其中 $\mathcal{V}$ 是协议约定的消息空间；接收方 R 可以根据协议要求，输入其本地的随机辅助信息。在双方完成规定的交互步骤后，S 输出最终的承诺值 $c \in \mathcal{C}$ ，以及自己留存的一组局部辅助信息 d_S ；R 则输出一组用于后续验证承诺的局部辅助信息 d_R 。其中 $\mathcal{C}$ 是协议规定的承诺值空间。从形式化角度讲，承诺阶段的交互过程可以表示为： $(c, d_S, d_R) \leftarrow \text{Commit}(S(v), R())$ 这一过程中，发送方和接收方之间可能会进行多轮的消息交互，具体的交互流程由协议的具体方案构造决定。
2. **揭示阶段 Reveal**：这是一个由接收方执行的确定性验证算法，其输入为接收方在承诺阶段获取的承诺值 c 、发送方在揭示阶段公开的原消息 v 以及发送方留存的局部辅助信息 d_S ，还有接收方自己在承诺阶段生成的辅助验证信息 d_R 。该算法的输出是一个二进制的验证判定结果 $b \in \{0, 1\}$ ，其中 $b = 1$ 表示接收方接受这个揭示为合法有效的承诺打开， $b = 0$ 表示接收方拒绝这个打开承诺。形式化上，这一验证过程可以表示为： $b \leftarrow \text{Reveal}(c, v, d_S, d_R)$ 在非交互式的承诺协议中，揭示阶段的所有信息都由发送方一次性发送给接收方，接收方本地执行验证算法，不需要再和发送方进行额外的交互。

关于这个系统模型，有几个极其重要的技术细节需要特别强调，理解这些细节是后续理解协议安全性的前提：

- **公开参数：**对于一个具体的承诺协议方案，在协议正式执行之前，通常需要由可信第三方生成并向所有参与方公布一组公开的协议参数。这类公开参数不会影响协议的安全性，也不需要由任何参与方保密，所有参与方都可以获取、校验并使用这些参数。在本讲义后续介绍的 Pedersen 承诺和 Naor 承诺方案中，将分别详细说明其公开参数的生成逻辑和校验方法。
- **非交互性与交互性：**承诺协议可以根据承诺阶段的交互轮次分为非交互承诺和交互承诺两类。非交互承诺指的是在承诺阶段，发送方仅需向接收方发送一条消息，交互就可以完成；而交互承诺则需要发送方和接收方之间进行多轮的消息交互和参数校验。本讲义后续介绍的 Pedersen 承诺属于非交互承诺，其交互效率更高，更适合在网络延迟较高的场景中使用；而 Naor 承诺则属于交互承诺，需要接收方在承诺阶段先向发送方发送一条辅助消息，再完成承诺流程。
- **算法的计算能力限制：**构成承诺协议的 Commit 和 Reveal 两个算法，都必须是概率多项式时间算法。这一要求的实际含义是：这两个算法的执行时间，都不会超过输入消息长度的某个多项式倍数；换言之，算法的执行效率必须是“高效可行”的，不能存在指数级别的计算复杂度，保证协议可以在实际的算力资源下正常运行。

5.2 安全模型与安全性定义

在密码学的形式化安全框架中，承诺协议的安全属性根据敌手能力的不同，严格分为三个安全级别，这三个级别的安全强度依次递增，分别对应着不同的抗敌手能力：

1. **计算安全 (Computational Security)：**该级别的安全保护仅能抵抗具有 多项式时间计算能力的有效敌手。也就是说，任何多项式时间运行的敌手，都只能以一个极其微小的、可以忽略的概率成功攻破协议的安全保护。这是在计算困难性假设（比如离散对数假设、因数分解假设）下，密码学方案能实现的最主流的安全级别。
2. **统计安全 (Statistical Security)：**该级别的安全保护可以抵抗具有 无限计算能力的敌手，不论敌手拥有多强的算力资源，都无法攻破协议的安全保护。但这一安全级别有一个前提限制：敌手只能拥有协议执行过程中公开的、多项式规模的交互数据，不能获取参与方的局部私密信息。
3. **完美安全 (Perfect Security)：**这是强度最高的安全级别，它和统计安全的抗敌手能力完全一致，但额外要求，协议的安全性分析不依赖于任何统计上的“可忽略概率”假设，即不存在任何微小的安全漏洞概率，是完全、绝对的安全。

基于这三个安全级别，我们可以将承诺协议的两个核心安全属性（隐藏性和绑定性），分别形式化为对应的安全等级定义。在实际应用中，最常用的安全属性组合是 计算绑定 + 统计隐藏，以及 统计绑定 + 计算隐藏，这也正是本讲义后续将详细介绍的 Pedersen 方案和 Naor 方案分别实现的目标。需要特别强调的是，在密码学的安全证明逻辑中，这两个安全属性是通过两个完全独立的安全实验来定义的，即我们分别针对“恶意的接收方”和“恶意的发送方”两类不同的攻击场景，分别设计实验，验证协议是否满足对应的安全属性，这两类敌手的攻击目标完全不同。

5.3 隐藏性 (Hiding)

隐藏性是针对 恶意接收方的安全属性，其核心目标是保证接收方无法在承诺阶段完成后，未打开承诺之前，获取到被承诺消息的任何相关信息。更严格地说，隐藏性要求：即使接收方不遵守协议的规则流程，试图通过自己接收到的承诺值来反向推断发送方承诺的消息内容，也无法有效获取任何有价值的信息。在密码学的形式化证明框架中，隐藏性是通过一个名为 $\text{Exp}_{\text{Com}}^{\text{hide}}$ 的安全实验来形式化定义的，这个实验的执行逻辑如下：

定义 5.2 (隐藏性安全实验). 对于给定的承诺协议 $\text{Com} = (\text{Commit}, \text{Reveal})$ 、恶意接收方敌手 $\mathcal{A}$ ，以及安全参数 κ （即决定协议安全强度的核心参数，一般取 128、256 等二进制长度值），隐藏性安全实验 $\text{Exp}_{\text{Com}}^{\text{hide}}(\mathcal{A}, \kappa)$ 的执行流程为：

1. **挑战消息生成**：实验环境首先随机选择两个完全相同长度的消息 $v_0, v_1 \in \mathcal{V}$ ，这两个消息将作为发送方的候选承诺消息。
2. **承诺阶段执行**：实验环境模拟诚实的发送方 Commit 算法，根据敌手 $\mathcal{A}$ 的交互响应，生成对应消息 v_b 的承诺值 c ，其中 $b \in \{0, 1\}$ 是实验环境随机选择的一个挑战比特值。
3. **敌手猜测输出**：恶意接收方敌手 $\mathcal{A}$ 在获取到承诺值 c 后，在其执行时间上限内，输出一个对挑战比特 b 的猜测值 $b' \in \{0, 1\}$ 。
4. **实验结果判定**：如果敌手的猜测值 b' 和实验环境选择的真实比特值 b 相等，即 $b' = b$ ，则实验输出为 1，代表敌手攻击成功；反之，若 $b' \neq b$ ，则实验输出为 0，代表敌手攻击失败。

基于这个实验，我们可以进一步量化定义敌手的攻击优势，进而给出不同级别的隐藏性安全属性的形式化定义：

定义 5.3 (隐藏性). 给定承诺协议 Com ，安全参数 κ ，以及恶意接收方敌手 $\mathcal{A}$ ，我们定义 $\mathcal{A}$ 在攻击该协议的隐藏性时的优势为： $\text{Adv}_{\text{Com}}^{\text{hide}}(\mathcal{A}, \kappa) = \left| \Pr [\text{Exp}_{\text{Com}}^{\text{hide}}(\mathcal{A}, \kappa) = 1] - \frac{1}{2} \right|$ 基于该优势，我们可以定义三个级别的隐藏性安全属性：

1. **统计隐藏性**: 对于任意一个可以在多项式时间内运行的恶意接收方敌手 $\mathcal{A}$, 其攻击该协议的隐藏性优势 $\text{Adv}_{\text{Com}}^{\text{hide}}(\mathcal{A}, \kappa)$, 当安全参数 κ 足够大时, 是一个可以忽略的函数。
2. **计算隐藏性**: 对于任意一个具有无限计算能力的恶意接收方敌手 $\mathcal{A}$, 其攻击该协议的隐藏性优势 $\text{Adv}_{\text{Com}}^{\text{hide}}(\mathcal{A}, \kappa)$, 当安全参数 κ 足够大时, 是一个可以忽略的函数。
3. **完美隐藏性**: 对于任意的敌手 $\mathcal{A}$, 其攻击该协议的隐藏性优势 $\text{Adv}_{\text{Com}}^{\text{hide}}(\mathcal{A}, \kappa)$, 都精确等于 0, 即敌手完全没有任何优势, 和随机猜测的结果没有任何区别。

这里需要对“可忽略函数”这一密码学基础概念做一个补充说明: 如果一个函数 $\epsilon(\kappa)$, 对于任意一个正多项式 $p(\cdot)$, 都存在一个对应的安全参数阈值 κ_0 , 使得当安全参数 $\kappa > \kappa_0$ 时, 始终有 $\epsilon(\kappa) < \frac{1}{p(\kappa)}$ 成立, 那么我们就称这个函数 $\epsilon(\kappa)$ 是可忽略的。通俗来讲, 可忽略函数的衰减速度, 比任何多项式的增长速度都要快, 当安全参数达到一定规模后, 这个函数的值会变得极其微小, 以至于在实际应用中完全可以忽略。在这个实验框架下, 隐藏性的本质可以被理解为: 承诺值 c 的概率分布, 与被承诺的消息 v 的内容是统计独立的。换句话说, 接收方拿到承诺值 c 后, 无法根据 c 的任何特征, 区分出 c 是对应消息 v_0 的承诺值, 还是对应消息 v_1 的承诺值——这正是“接收方无法获取承诺消息的任何信息”这一安全目标的形式化表达。

5.4 绑定性 (Binding)

绑定性是针对 恶意发送方的安全属性, 其核心目标是保证发送方无法“作弊”——即无法在承诺阶段完成后, 通过篡改自己的局部辅助信息, 将同一个承诺值 c , “打开”为两个不同的有效值 v 和 v' 。更严格地说, 绑定性要求: 即使发送方不遵守协议的规则流程, 在揭示阶段伪造验证信息, 也无法让接收方接受两个不同的消息为同一个承诺值的合法揭示结果。和隐藏性类似, 绑定性的形式化定义, 也是通过一个对应的安全实验 $\text{Exp}_{\text{Com}}^{\text{bind}}$ 来给出的:

定义 5.4 (绑定性安全实验). 对于给定的承诺协议 $\text{Com} = (\text{Commit}, \text{Reveal})$ 、恶意发送方敌手 $\mathcal{A}$, 以及安全参数 κ , 绑定性安全实验 $\text{Exp}_{\text{Com}}^{\text{bind}}(\mathcal{A}, \kappa)$ 的执行流程为:

1. **恶意承诺执行**: 恶意发送方敌手 $\mathcal{A}$ 与诚实的接收方进行交互, 执行承诺阶段的协议流程。在交互过程中, 敌手可以根据自己的攻击策略, 随意构造发送给接收方的消息; 而诚实的接收方则严格按照协议规则生成自己的局部辅助信息 d_R 。
2. **承诺伪造结果输出**: 交互结束后, 敌手 $\mathcal{A}$ 输出一个三元组 (c, v, v', d_S, d'_S) , 其中 c 是敌手在承诺阶段发送给接收方的承诺值, v 和 v' 是两个不同的消息 (即 $v \neq v'$), d_S 和 d'_S 是敌手伪造的、用于打开承诺值 c 的两组局部辅助验证信息。

3. **验证结果判定**：实验环境调用诚实的接收方所使用的 Reveal 验证算法，分别对这两组揭示信息进行校验，得到两个验证结果 $b = \text{Reveal}(c, v, d_S, d_R)$ 和 $b' = \text{Reveal}(c, v', d'_S, d_R)$ 。如果这两个验证结果都为 1，即 $b = b' = 1$ ，则实验输出为 1，代表敌手攻击成功；反之，实验输出为 0，代表敌手攻击失败。

基于这个实验，我们可以同样量化定义敌手的攻击优势，进而给出不同级别的绑定性安全属性的形式化定义：

定义 5.5 (绑定性). 给定承诺协议 Com ，安全参数 κ ，以及恶意发送方敌手 $\mathcal{A}$ ，我们定义 $\mathcal{A}$ 在攻击该协议的绑定性时的优势为： $\text{Adv}_{\text{Com}}^{\text{bind}}(\mathcal{A}, \kappa) = \Pr [\text{Exp}_{\text{Com}}^{\text{bind}}(\mathcal{A}, \kappa) = 1]$ 基于该优势，我们可以定义三个级别的绑定性安全属性：

1. **统计绑定性**：对于任意一个可以在多项式时间内运行的恶意发送方敌手 $\mathcal{A}$ ，其攻击该协议的绑定性优势 $\text{Adv}_{\text{Com}}^{\text{bind}}(\mathcal{A}, \kappa)$ ，当安全参数 κ 足够大时，是一个可以忽略的函数。
2. **计算绑定性**：对于任意一个具有无限计算能力的恶意发送方敌手 $\mathcal{A}$ ，其攻击该协议的绑定性优势 $\text{Adv}_{\text{Com}}^{\text{bind}}(\mathcal{A}, \kappa)$ ，当安全参数 κ 足够大时，是一个可以忽略的函数。
3. **完美绑定性**：对于任意的敌手 $\mathcal{A}$ ，其攻击该协议的绑定性优势 $\text{Adv}_{\text{Com}}^{\text{bind}}(\mathcal{A}, \kappa)$ ，都精确等于 0，即敌手完全不可能构造出这样的“碰撞”揭示结果。

从这一形式化定义可以看出，绑定性的本质，实际上是要求承诺算法 Commit 具有某种“抗碰撞性”——也就是说，找到两个不同的消息 v 和 v' ，以及对应的随机辅助信息 d_S 和 d'_S ，使得这两组输入能生成完全相同的承诺值 c ，这件事在计算上是不可行的，或是在统计上几乎不可能的。

5.5 安全属性的不可能性结果

在介绍具体的协议方案之前，我们必须先介绍密码学中关于承诺协议的一个基础性的不可能性结果，这是理解后续方案安全属性设计逻辑的关键前提。

定理 5.6 (不可能性结果). 不存在同时满足完美隐藏性和完美绑定性的承诺协议。

这一结论的逻辑证明思路并不复杂：假设存在一个同时满足完美隐藏性和完美绑定性的承诺协议，那么根据完美隐藏性的定义，无论承诺值 c 是什么，它都和任意一个被承诺的消息 v 的内容统计独立；换句话说，对于任意的承诺值 c ，以及任意的消息 $v \in \mathcal{V}$ ，都必然存在一组对应的局部辅助信息 d_S ，使得 $\text{Reveal}(c, v, d_S, d_R) = 1$ 成立。但这一结论，直接和完美绑定性的定义相矛盾——完美绑定性要求，对于同一个承诺值 c ，不可能存在两个不同的消息 v 和 v' ，使得它们的验证结果同时为 1。这一不可能性结果，直接决定了在

实际的密码协议设计场景中，我们无法构造出一个同时具备最强级别隐藏性和最强级别绑定性的承诺协议。因此，在实际应用中，我们必须根据业务场景的安全需求优先级，选择合适的安全属性组合。而这也正是本讲义后续将介绍 Pedersen 方案和 Naor 方案的核心原因：这两套方案分别实现了两种最常用、互补的安全属性组合，足以覆盖绝大多数实际应用场景的安全需求。

5.6 方案构造 I: Pedersen 承诺协议（计算绑定 + 统计隐藏）

Pedersen 承诺协议是 1991 年由密码学家 Torben P. Pedersen 在密码学顶级会议 CRYPTO 上发表的经典方案，是目前已知的效率最高、应用最广泛的承诺协议~[9]。该方案构造在循环群的密码学困难假设之上，其安全属性组合为 统计隐藏性 + 计算绑定性，是一种典型的“非交互式”承诺协议——在承诺阶段，发送方仅需给接收方发送一条消息，交互就可以完成。这一特性使得该协议在网络延迟较高或通信轮次受限的场景中，具有天然的应用优势。

5.6.1 前提假设与公开参数生成

Pedersen 承诺协议的安全性依赖于经典的 离散对数困难性假设，这是数论中一个被广泛研究和认可的密码学困难假设。在构造协议之前，我们需要先定义一个满足该假设的循环群，以及相关的公开全局参数。

定义 5.7 (循环群与生成元). 设 G 是一个阶为素数 q 的有限循环群，其中 q 的二进制长度就是该协议的安全参数 κ 。这意味着，在实际应用中， q 一般是一个长度为 2048 位或 4096 位的大素数，以保证离散对数问题的求解难度足够高。设 g 是循环群 G 的一个生成元，这意味着 g 可以通过幂次运算生成群 G 中的所有元素。

基于这个循环群，我们可以定义 Pedersen 承诺协议的公开参数生成逻辑。需要特别强调的是，这些公开参数的生成过程必须由可信第三方来执行，或者由协议的所有参与方协同执行一个“参数生成协议”来生成，以确保参数不会被恶意第三方篡改。

方案构造 5.8 (Pedersen 承诺公开参数). Pedersen 承诺协议的公开参数由可信第三方按照以下逻辑生成：

1. 选择一个安全的循环群 G ，其阶为大素数 q ，生成元为 g ；
2. 从群 G 中随机选择一个元素 h ，且保证 $h \neq g$ 。为了保证参数的安全性，我们要求 h 是 g 的一个随机幂次值，即存在一个随机数 $x \in \mathbb{Z}_q^*$ ，使得 $h = g^x$ ，但 x 这个值必须由可信第三方在生成完成后立即销毁，不能向任何参与方公开，也不能由任何参与方推算出来。

最终, 协议的公开参数集合为 $\text{params} = (\mathbb{G}, q, g, h)$, 所有参与方都可以获取这份公开参数集合。

在实际应用中, 这类公开参数往往是由标准组织或行业领军企业提前生成并公开的, 比如在区块链应用中, Pedersen 承诺的公开参数一般会作为链的创世参数一部分, 被所有节点同步校验。

5.6.2 协议构造

Pedersen 承诺协议是一个非交互式协议, 其承诺阶段不需要接收方发送任何辅助消息, 协议的完整流程由以下两个算法组成。

方案构造 5.9 (Pedersen 承诺协议). 给定公开参数 $\text{params} = (\mathbb{G}, q, g, h)$, Pedersen 承诺协议的两个核心算法的执行逻辑为:

1. **承诺阶段 Commit:** 发送方 S 待承诺的消息必须是一个位于有限域 $\mathbb{Z}_q$ 中的元素, 即 $v \in \mathbb{Z}_q$ 。这里的 $\mathbb{Z}_q$ 表示的是从 0 到 $q-1$ 的所有整数构成的集合, 集合中的元素加法、乘法运算结果均需要对素数 q 取模。如果实际待承诺的消息是二进制字符串或其他数据格式, 发送方需要先将其编码为 $\mathbb{Z}_q$ 中的元素格式。在正式生成承诺值之前, 发送方需要先从 $\mathbb{Z}_q$ 中随机选取一个秘密的随机数 r , 这个随机数被称为“承诺随机数”, 将作为发送方的局部辅助信息留存, 不会被公开给接收方或其他第三方。随后, 发送方使用自己的私密随机数 r 和消息 v , 按照以下公式计算出承诺值 c : $c = g^v \cdot h^r$ 。这里的幂次运算和乘法运算, 都是在循环群 $\mathbb{G}$ 中的运算规则下执行的。计算完成后, 发送方将生成的承诺值 c 发送给接收方。此时, 发送方的局部辅助信息为 $d_S = (v, r)$, 即待承诺的消息和私密随机数; 而接收方收到承诺值 c 后, 将其作为自己的局部辅助信息, 即 $d_R = c$ 。
2. **揭示阶段 Reveal:** 当需要打开承诺时, 发送方将自己承诺的消息 v , 以及留存的私密随机数 r , 一并发送给接收方。接收方在收到这两个值后, 首先需要验证 v 和 r 都是 $\mathbb{Z}_q$ 中的合法元素, 随后使用公开参数中的 g 、 h , 以及自己在承诺阶段获取的承诺值 c , 按照和承诺阶段完全一致的计算逻辑, 重新计算一遍承诺值 $c' = g^v \cdot h^r$ 。接下来, 接收方将重新计算的承诺值 c' , 和自己在承诺阶段收到的原始承诺值 c 进行恒等校验: 如果 $c' = c$, 则验证算法输出 $b = 1$, 代表接收方认可这个揭示结果是合法有效的; 反之, 如果 $c' \neq c$, 则验证算法输出 $b = 0$, 代表接收方拒绝这个揭示结果, 认为其不合法。

需要特别强调的是, 在这个协议中, 随机数 r 的保密性和不可预测性, 是整个协议安全性的核心基础。如果发送方在生成不同的承诺值时使用了相同的随机数 r , 或者 r 被第

三方推算出来，那么整个协议的隐藏性都会被直接攻破，第三方可以从承诺值 c 中直接获取到被承诺消息 v 的内容。

5.6.3 基于模拟的安全性证明

我们将采用现代密码学中标准的基于模拟的证明范式，来证明 Pedersen 承诺协议确实满足统计隐藏性和计算绑定性的安全属性组合。基于模拟的证明范式的核心逻辑是：对于任何一个真实环境下的恶意敌手 $\mathcal{A}$ ，我们都可以构造一个对应的模拟器 Sim ，该模拟器不拥有任何关于被承诺消息的额外信息，仅通过和敌手 $\mathcal{A}$ 的交互，就能模拟出真实协议执行时的所有公开消息内容。如果模拟器生成的模拟执行环境，和真实协议的执行环境是不可区分的，那么就能证明协议在安全属性上是安全的。

5.6.4 统计隐藏性证明

定理 5.10. *Pedersen 承诺协议在基于模拟的安全范式下，满足统计隐藏性安全属性。*

证明. 我们需要构造一个有效的模拟器 Sim ，使得对于任意一个恶意的接收方敌手 $\mathcal{A}$ ，在真实协议执行环境中，敌手 $\mathcal{A}$ 与诚实发送方交互时的视图（即敌手在协议执行过程中获取的所有信息的集合），与在模拟器 Sim 构造的模拟环境中，敌手 $\mathcal{A}$ 与模拟器交互时的视图，在统计上是不可区分的。**模拟器构造逻辑：**对于任意一个待承诺的消息 $v^* \in \mathbb{Z}_q$ ，模拟器 Sim 在不掌握任何关于 v^* 的私密信息的前提下，仅通过公开参数，即可按照以下逻辑生成一个和真实承诺值统计上不可区分的模拟承诺值 c ：

1. 从 $\mathbb{Z}_q$ 中随机选取一个随机数 r' ；
2. 直接计算模拟承诺值 $c' = h^{r'}$ ，其中 h 是公开参数中的群元素；
3. 将 c' 作为模拟的承诺值发送给敌手 $\mathcal{A}$ 。

不可区分性证明：在真实协议执行环境中，当诚实的发送方承诺消息 v 时，发送方会使用自己的私密随机数 r 计算出承诺值 $c = g^v \cdot h^r$ 。由于 h 是循环群 $\mathbb{G}$ 中的一个元素，根据循环群的生成元性质，必然存在一个指数 $x \in \mathbb{Z}_q^*$ ，使得 $h = g^x$ 。因此，真实承诺值 c 的计算逻辑可以改写为 $c = g^v \cdot (g^x)^r = g^{v+xr}$ 。而在模拟器构造的模拟环境中，模拟器生成的模拟承诺值为 $c' = h^{r'} = g^{xr'}$ 。由于 r 和 r' 都是从 $\mathbb{Z}_q$ 中随机选取的，且循环群 $\mathbb{G}$ 的阶 q 是一个大素数，因此， $v + xr$ 和 xr' 这两个值在 $\mathbb{Z}_q$ 中，都是服从均匀分布的随机变量。这意味着，真实承诺值 c 和模拟承诺值 c' ，在统计上具有完全相同的概率分布。因此，对于任意的恶意接收方敌手 $\mathcal{A}$ ，其在真实协议执行环境中的视图和在模拟环境中的视图是统计不可区分的，二者的统计区分优势完全为 0。根据统计隐藏性的定义，我们可以直接得出结论：Pedersen 承诺协议满足统计隐藏性。 $\square$

5.6.5 计算绑定性证明

定理 5.11. 如果在循环群 $\mathbb{G}$ 上，离散对数问题是计算困难的，那么 Pedersen 承诺协议在基于模拟的安全范式下，满足计算绑定性安全属性。

证明. 我们采用反证法来证明这一结论。假设 Pedersen 承诺协议不满足计算绑定性，那么这意味着，存在一个概率多项式时间的恶意发送方敌手 $\mathcal{A}$ ，可以在绑定性安全实验中，以一个不可忽略的优势 ϵ ，成功输出两个不同的消息 v 和 v' ，以及对应的两组随机数 r 和 r' ，使得这两组输入生成的承诺值完全相同，即 $g^v \cdot h^r = g^{v'} \cdot h^{r'}$ 。我们可以利用这个能攻破绑定性的敌手 $\mathcal{A}$ ，构造出一个能在多项式时间内解决循环群 $\mathbb{G}$ 上离散对数问题的算法。**归约算法构造逻辑：**假设我们需要求解循环群 $\mathbb{G}$ 上的一个离散对数挑战，即给定 g 和 h ，找到 $x \in \mathbb{Z}_q^*$ ，使得 $h = g^x$ 。我们可以按照以下逻辑构造一个离散对数求解算法：

1. 将公开参数 $\text{params} = (\mathbb{G}, q, g, h)$ 作为输入，提供给恶意发送方敌手 $\mathcal{A}$ ；
2. 敌手 $\mathcal{A}$ 输出一个碰撞结果：两个不同的消息 $v, v' \in \mathbb{Z}_q$ ，以及对应的两组随机数 $r, r' \in \mathbb{Z}_q$ ，满足 $g^v \cdot h^r = g^{v'} \cdot h^{r'}$ ；
3. 由于 $v \neq v'$ ，我们可以对上述等式进行变形，最终推导出 $h = g^{\frac{v'-v}{r-r'}}$ 。这意味着，我们可以直接计算出 $x = \frac{v'-v}{r-r'}$ ，这个值就是 h 基于生成元 g 的离散对数。

根据我们的假设，敌手 $\mathcal{A}$ 可以在多项式时间内，以不可忽略的优势 ϵ 输出这样的碰撞结果，那么这意味着，我们构造的这个离散对数求解算法，也可以在多项式时间内，以不可忽略的优势 ϵ ，成功解决循环群 $\mathbb{G}$ 上的离散对数问题。但这一结论，和“循环群 $\mathbb{G}$ 上的离散对数问题是计算困难的”这一前提假设直接矛盾。因此，我们的初始假设不成立，不存在这样的概率多项式时间敌手 $\mathcal{A}$ 可以攻破 Pedersen 承诺协议的绑定性。根据计算绑定性的定义，我们可以得出结论：Pedersen 承诺协议满足计算绑定性。 $\square$

5.7 方案构造 II：Naor 承诺协议（统计绑定 + 计算隐藏）

Naor 承诺协议是 1991 年由密码学家 Moni Naor 在密码学顶级期刊《Journal of Cryptology》上发表的经典方案~[10]，其安全属性组合恰好与 Pedersen 承诺协议形成互补——统计绑定性 + 计算隐藏性。该方案的构造基础是任意一个具有伪随机性的密码学高效伪随机生成器（PRG），这使得该方案可以基于任何单向函数来实例化，在理论密码学中具有非常重要的价值。与 Pedersen 承诺协议不同，Naor 承诺协议是一个交互式承诺协议——在承诺阶段，需要接收方先向发送方发送一条随机的辅助消息，随后发送方再基于这条消息生成承诺值。

5.7.1 前提假设与公开参数生成

Naor 承诺协议的安全性依赖于伪随机生成器 (PRG) 的伪随机性这一基础假设。在构造协议之前, 我们需要先明确定义伪随机生成器的技术标准。

定义 5.12 (伪随机生成器). 设 $G : \{0, 1\}^\kappa \rightarrow \{0, 1\}^{2\kappa}$ 是一个确定性的密码学算法, 其输入是一个长度为 κ 的二进制随机种子, 输出是一个长度为 2κ 的二进制字符串。如果这个算法 G 满足以下两个条件, 那么它就是一个安全的伪随机生成器:

1. **扩展性**: 输出的二进制字符串长度, 严格大于输入的种子长度;
2. **伪随机性**: 对于任意一个概率多项式时间的算法区分器 $\mathcal{D}$, 其区分 “ G 的输出字符串” 和 “真正的随机字符串 (长度与 G 的输出相同)” 的优势, 是一个可忽略的函数。

基于这个伪随机生成器, 我们可以定义 Naor 承诺协议的公开参数。需要特别指出的是, Naor 承诺协议的公开参数非常简单, 不需要依赖可信第三方进行复杂的参数生成, 仅需要双方认可的伪随机生成器 G 和安全参数 κ 。

5.7.2 协议构造

Naor 承诺协议是一个交互式协议, 其承诺阶段需要接收方和发送方进行一次消息交互, 完整的协议流程由以下两个算法和交互步骤组成。

方案构造 5.13 (Naor 承诺协议). 给定安全参数 κ 和伪随机生成器 $G : \{0, 1\}^\kappa \rightarrow \{0, 1\}^{2\kappa}$, Naor 承诺协议的完整交互流程为:

1. **承诺阶段交互步骤 1 (接收方 $\rightarrow$ 发送方)**: 接收方 R 首先从 $\{0, 1\}^\kappa$ 中随机选取一个长度为 κ 的二进制字符串 s , 作为自己的随机种子。随后, 接收方将这个随机种子 s 使用伪随机生成器 G 进行加密处理, 得到一个长度为 2κ 的加密字符串 $G(s)$ 。紧接着, 接收方将这个加密后的字符串 $G(s)$ 发送给发送方 S , 作为承诺阶段的第一条交互消息。此时, 接收方需要将自己选择的随机种子 s 作为局部私密信息留存, 不能发送给发送方或其他第三方。
2. **承诺阶段交互步骤 2 (发送方 $\rightarrow$ 接收方)**: 发送方 S 待承诺的消息是一个二进制比特 $v \in \{0, 1\}$ 。如果实际待承诺的消息是一个长度大于 1 的二进制字符串, 发送方可以将消息拆分成多个单独的比特, 对每个比特分别执行一次 Naor 承诺协议, 最终完成对整个字符串的承诺。在收到接收方发来的加密字符串 $G(s)$ 后, 发送方从 $\{0, 1\}^\kappa$ 中随机选取一个长度为 κ 的二进制字符串 r , 作为自己的承诺随机数。随后, 发送方根据自己待承诺的比特 v , 按照以下逻辑计算承诺值 c :

- 如果待承诺的比特 $v = 0$ ，那么发送方直接将随机数 r 使用伪随机生成器 G 进行加密处理，得到的结果 $G(r)$ 作为承诺值 c ；
- 如果待承诺的比特 $v = 1$ ，那么发送方将自己的随机数 r 对应的加密字符串 $G(r)$ ，与接收方发来的加密字符串 $G(s)$ 进行一次逐位异或（XOR）运算，将运算结果 $G(r) \oplus G(s)$ 作为承诺值 c 。

计算完成后，发送方将承诺值 c 发送给接收方。此时，发送方的局部辅助信息为 $d_S = (v, r)$ ，即待承诺的比特和自己的承诺随机数；而接收方的局部辅助信息为 $d_R = s$ ，即自己的随机种子。

3. **揭示阶段 Reveal**: 当需要打开承诺时，发送方将自己承诺的消息 v ，以及留存的承诺随机数 r ，一并发送给接收方。接收方在收到这两个值后，首先会重新计算一遍 $G(r)$ ，随后结合自己留存的私密种子 s 对应的加密字符串 $G(s)$ ，根据 v 的值，按照和承诺阶段完全一致的逻辑，重新生成一遍承诺值 c' ：

- 如果 $v = 0$ ，那么接收方计算 $c' = G(r)$ ；
- 如果 $v = 1$ ，那么接收方计算 $c' = G(r) \oplus G(s)$ 。

计算完成后，接收方将重新计算的承诺值 c' ，和自己在承诺阶段收到的原始承诺值 c 进行恒等校验：如果 $c' = c$ ，则验证算法输出 $b = 1$ ，代表接收方认可这个揭示结果是合法有效的；反之，如果 $c' \neq c$ ，则验证算法输出 $b = 0$ ，代表接收方拒绝这个揭示结果，认为其不合法。

需要特别强调的是，在这个协议中，接收方的随机种子 s 的保密性，是整个协议安全性的核心基础。如果发送方在承诺阶段获取到了 s 的具体值，那么它就可以轻易地构造出“碰撞”承诺值，攻破协议的绑定性；反之，如果接收方在承诺阶段完成后泄露了 s ，那么它就可以直接打开发送方的承诺值，获取到被承诺消息的内容，直接攻破协议的隐藏性。

5.7.3 基于模拟的安全性证明

我们将继续使用基于模拟的证明范式，来证明 Naor 承诺协议确实满足 统计绑定性和计算隐藏性的安全属性组合。

5.7.4 统计绑定性证明

定理 5.14. *Naor 承诺协议在基于模拟的安全范式下，满足统计绑定性安全属性。*

证明. 根据绑定性的定义，我们需要证明的是，对于任意一个恶意发送方敌手 $\mathcal{A}$ ，即使它拥有无限的计算能力，也无法在承诺阶段结束后，找到两个不同的比特值 v 和 v' ，以及对

应的两组随机数 r 和 r' ，使得这两组输入生成的承诺值完全相同。我们依然采用反证法来证明这一结论。假设 Naor 承诺协议不满足统计绑定性，那么这意味着，存在一个恶意发送方敌手 $\mathcal{A}$ ，可以在承诺阶段结束后，找到两个不同的比特值 v 和 v' （即 $v \neq v'$ ），以及对应的两组随机数 $r, r' \in \{0, 1\}^\kappa$ ，使得这两组输入生成的承诺值完全相同。我们分两种情况讨论这一假设下的矛盾关系：

1. **情况 1：敌手找到的碰撞满足 $v = 0, v' = 1$ 。**在这种情况下，根据协议的承诺值计算逻辑，敌手构造的碰撞要求 $G(r) = G(r') \oplus G(s)$ 。对该等式两边同时进行逐位异或运算，可以推导出 $G(s) = G(r) \oplus G(r')$ 。这意味着，敌手可以在不知道接收方种子 s 的情况下，计算出 $G(s)$ 的值。但根据伪随机生成器的定义， $G(s)$ 是一个长度为 2κ 的伪随机字符串，其和一个真正的随机字符串的区分概率是可忽略的。因此，敌手能找到这样的 r 和 r' 的概率，是完全可以忽略的。
2. **情况 2：敌手找到的碰撞满足 $v = 1, v' = 0$ 。**这种情况和情况 1 在逻辑上完全对称，可以推导出完全相同的矛盾关系。

综合以上两种情况，我们可以得出结论：即使恶意发送方敌手 $\mathcal{A}$ 拥有无限的计算能力，它能找到这样的碰撞结果的概率，也是一个可忽略的函数。根据统计绑定性的定义，Naor 承诺协议满足统计绑定性。 $\square$

5.7.5 计算隐藏性证明

定理 5.15. 如果伪随机生成器 G 满足其伪随机性定义要求，那么 Naor 承诺协议在基于模拟的安全范式下，满足计算隐藏性安全属性。

证明. 我们需要构造一个有效的模拟器 Sim ，使得对于任意一个概率多项式时间的恶意接收方敌手 $\mathcal{A}$ ，其在真实协议执行环境中的视图，与在模拟器构造的模拟环境中的视图，是计算不可区分的。**模拟器构造逻辑：**模拟器 Sim 按以下逻辑生成模拟的承诺值，与恶意接收方敌手 $\mathcal{A}$ 进行交互：

1. 从 $\{0, 1\}^\kappa$ 中随机选取一个长度为 κ 的二进制字符串 r' ，作为模拟的承诺随机数；
2. 从 $\{0, 1\}^{2\kappa}$ 中随机选取一个长度为 2κ 的二进制字符串 c' ，作为模拟的承诺值；
3. 将 c' 发送给敌手 $\mathcal{A}$ ，作为模拟的承诺值。

不可区分性证明：在真实协议执行环境中，根据待承诺比特 v 的不同，承诺值的计算逻辑分为两种：

- 如果 $v = 0$ ，则承诺值 $c = G(r)$ ，其中 r 是发送方的随机数；

- 如果 $v = 1$ ，则承诺值 $c = G(r) \oplus G(s)$ ，其中 s 是接收方的种子。

而在模拟环境中，模拟器生成的模拟承诺值 c' 是一个完全随机的长度为 $2k$ 的二进制字符串。根据伪随机生成器的伪随机性定义，对于任意一个概率多项式时间的区分器 $\mathcal{A}$ ，它区分“真实的承诺值 c ”和“模拟的承诺值 c' ”的优势，是一个可忽略的函数。因此，恶意接收方敌手 $\mathcal{A}$ 无法在多项式时间内，以一个不可忽略的优势，区分出自己是在和真实的发送方交互，还是在和模拟器交互。这意味着，敌手 $\mathcal{A}$ 在真实协议执行环境中的视图和在模拟环境中的视图，是计算不可区分的。根据计算隐藏性的定义，Naor 承诺协议满足计算隐藏性。□

5.8 结论

承诺协议是构造绝大多数高级密码协议的核心基础积木，其安全属性的组合选择，直接决定了上层应用的安全边界。本讲义详细阐述了承诺协议的系统模型、安全模型与形式化的安全属性定义，深入讲解了两套在密码学理论和实际应用中都极为重要的经典方案构造——Pedersen 承诺协议和 Naor 承诺协议。这两套方案的安全属性互补，各自具有明确的适用场景，其核心特征对比如下：

- **Pedersen 承诺协议**：基于经典的离散对数困难性假设，是一种非交互式承诺协议，通信轮次效率高。该方案实现了 统计隐藏性 + 计算绑定性的安全属性组合：统计隐藏性保证了即使敌手拥有无限计算能力，也无法在不打开承诺的情况下，获取承诺消息的任何内容；而计算绑定性则保证了在离散对数假设下，多项式时间算力的敌手无法构造出碰撞承诺值。这一方案特别适用于需要长期保证数据机密性的场景，比如区块链中的隐私交易协议、零知识证明类的隐私计算协议，以及其他需要非交互特性的安全协议场景。
- **Naor 承诺协议**：基于任意一个伪随机生成器这一基础密码学构件，是一种交互式承诺协议，需要通信双方进行一次额外的消息交互。该方案实现了 统计绑定性 + 计算隐藏性的安全属性组合：统计绑定性保证了即使敌手拥有无限计算能力，也无法构造出碰撞承诺值；而计算隐藏性则保证了在伪随机生成器的安全假设下，多项式时间算力的敌手无法在不打开承诺时获取到承诺消息的内容。这一方案的理论意义远大于其实际应用价值，它证明了“基于任何单向函数类的密码学原语，都可以构造出一个安全的承诺协议”这一重要结论，是很多理论密码学安全性归约证明的基础构件。

掌握这两套方案的技术细节、安全属性差异与适用场景边界，是理解、设计和分析更复杂的密码协议的关键基础。在实际应用中，选择哪套方案，需要根据具体业务场景的安全需求优先级、网络通信条件以及底层安全假设的可实现性来综合判断。

参考文献

- [1] 张秉晟, 张佳婕, and 秦湛. 通用图灵机及其对现代密码安全建模的影响. 中国计算机学会通讯, 15(7):10–14, July 2019.
- [2] Shafi Goldwasser, Silvio Micali, and Charles Rackoff. The knowledge complexity of interactive proof systems. *SIAM Journal on Computing*, 18(1):186–208, 1989.
- [3] Oded Goldreich, Silvio Micali, and Avi Wigderson. How to play any mental game. In *Proceedings of the 19th Annual ACM Symposium on Theory of Computing*, STOC '87, pages 218–229. ACM, 1987.
- [4] Donald Beaver, Silvio Micali, and Phillip Rogaway. The round complexity of secure protocols. In *Proceedings of the 22nd Annual ACM Symposium on Theory of Computing*, STOC '90, pages 503–513. ACM, 1990.
- [5] Ran Canetti. Universally composable security: A new paradigm for cryptographic protocols. In *Proceedings of the 42nd IEEE Symposium on Foundations of Computer Science*, FOCS '01, pages 136–145. IEEE Computer Society, 2001.
- [6] Yehuda Lindell. *How to Simulate It – A Tutorial on the Simulation Proof Technique*, pages 277–346. Information Security and Cryptography. Springer, Cham, 2017.
- [7] 杨波 and 杨启良. 密码学中的可证明安全性 (第 2 版). 网络空间安全学科系列教材. 清华大学出版社, 北京, 2 edition, 2024.
- [8] Dan Boneh and Victor Shoup. A Graduate Course in Applied Cryptography, January 2023.
- [9] Torben P. Pedersen. Non-interactive and information-theoretic secure verifiable secret sharing. In *Proceedings of the 11th Annual International Cryptology Conference*, CRYPTO '91, pages 129–140. Springer-Verlag, 1991.
- [10] Moni Naor. Bit commitment using pseudorandomness. In *Advances in Cryptology — Proceedings of CRYPTO '91*, volume 576 of *LNCS*, pages 128–142. Springer-Verlag, 1991.